Best Practices for Biomedical Research Data Management

Module 6: Biomedical Ethics

HIPAA: Health Insurance Portability & Accountability Act

Loren Maloney, JD, CHC, CHPC, UMass Medical School

This video will provide an overview of The Health Insurance Portability and Accountability Act of 1996 (the HIPAA Privacy Rule for human health data) as well as the issue of Data-De-Identification. It will identify & discuss privacy and regulatory issues surrounding the sharing of biomedical research data.

CC BY NC SA

Sharing Biomedical Research Data: Privacy & Regulatory Considerations

Disclaimer

- This information does not constitute legal advice and is for educational purposes only. This information is based on federal law and may not be current. This information does not take into account state law. This presentation is intended to be a general information resource regarding the matters covered, and should not be acted upon without advice and consultation with legal or other advisors as appropriate.

- The views and opinions expressed in this presentation are those of the author and do not necessarily reflect the official policy or position of the University of Massachusetts Medical School.

HIPAA Privacy Rule

- The HIPAA Privacy Rule limits the types of uses and disclosures of an individual's health information by Covered Entities, which includes most health care providers and insurers.
- HIPAA Privacy Rule is interpreted and enforced by US Health and Human Services (HHS) Office for Civil Rights (OCR) and State Office of Attorney General
- The Privacy Rule applies only to Protected Health Information (PHI), which is information that:
  - Relates to an individual's health, or the provision of health care to that individual; and that
  - Could be used to identify the individual.

HIPAA Privacy Rule & Research

- The Privacy Rule allows a Covered Entity to disclose PHI to an investigator for the purpose or research in 5 situations:
    1. When the individual who is the subject of the PHI has authorized in writing the use of PHI in specific research
    2. When the Covered Entity receives documentation that an Institutional Review Board (IRB) has waived the authorization requirement or approved the alteration of existing an authorization (IRB must meet standards described by Privacy Rule)
    3. When PHI will be used solely to prepare a research protocol (includes other requirements)
    4. When PHI is a “limited data set” with “direct identifiers” excluded
    5. When PHI is solely PHI of decedents

HIPAA Privacy Rule & Research

- HHS interprets the Privacy Rule to require that when an Authorization is obtained for research purposes, it pertains only to a specific research study, not to nonspecific research or to future, unspecified projects.
- The Privacy Rule considers the creation and maintenance of a research repository or database as a specific research activity, but the subsequent use or disclosure by a covered entity of information from the database for a specific research study will require separate Authorization unless the PHI use or disclosure is permitted without Authorization.

Data De-Identification

- De-Identification is one solution for the tension between privacy protection and data sharing
- De-Identification is the removal or addition of information to the data that prohibits the identification of the individual patient

1. Remove any of the 18 identifiers referenced on next slide; **OR**
2. The covered entity may obtain certification by "a person with appropriate knowledge of and experience with generally accepted statistical and scientific principles and methods for rendering information not individually identifiable" that there is a "very small" risk that the information could be used by the recipient to identify the individual who is the subject of the information, alone or in combination with other reasonably available information. The person certifying statistical de-identification must document the methods used as well as the result of the analysis that justifies the determination.

*** Remember that there are rules governing maintenance of de-identification documentation.**

Data De-Identification

- 18 Identifiers:
  - Names.
  - All geographic subdivisions smaller than a state, including street address, city, county, precinct, ZIP Code, and their equivalent geographical codes…
  - All elements of dates (except year) for dates directly related to an individual, including birth date, admission date, discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may be aggregated into a single category of age 90 or older.
  - Telephone numbers.
  - Facsimile numbers.
  - Electronic mail addresses.
  - Social security numbers.
  - Medical record numbers.
  - Health plan beneficiary numbers.
  - Account numbers.
  - Certificate/license numbers.
  - Vehicle identifiers and serial numbers, including license plate numbers.
  - Device identifiers and serial numbers.
  - Web universal resource locators (URLs).
  - Internet protocol (IP) address numbers.
  - Biometric identifiers, including fingerprints and voiceprints.
  - Full-face photographic images and any comparable images.
  - Any other unique identifying number, characteristic, or code, unless otherwise permitted by the Privacy Rule for re-identification.

Conclusion

- Sharing biomedical research data is often affected by external issues.
  - Privacy (HIPAA, Common Rule, etc.) v. Data Sharing (NIH, grants, etc.)
  - Control over research data by investigator v. organization or funding agency
  - Ethical duty to share information for the good of the public v. fiscal duty to capitalize on commercial viability
- Utilize interdisciplinary team to explore issues and develop appropriate solutions.